STATEX

INFORME DE AUDITORÍA DE SEGURIDAD

AUDITORÍA DE SEGURIDAD WEB Y APIS

Ejemplo SaaS (ficticio) · app.ejemplo.com

Versión	1.0 · 20 de octubre de 2026
Periodo de pruebas	del 13 al 17 de octubre de 2026
Preparado para	Dirección técnica de Ejemplo SaaS
Preparado por	StateX · Albert Sánchez y Jordi Sánchez

CONFIDENCIAL

CONTROL DEL DOCUMENTO

VERSIÓN	FECHA	CAMBIOS	AUTOR
1.0	20/10/2026	Informe inicial	AS · JS
1.1	—	Resultado del retest (pendiente)	—

Distribución: solo las personas designadas por Ejemplo SaaS (ficticio). Este documento contiene información sensible sobre la seguridad de sus sistemas.

CONTENIDO

1. Resumen ejecutivo
2. Alcance y autorización
3. Metodología
4. Resumen de hallazgos
5. Detalle de los hallazgos
6. Plan de corrección
7. Retest
8. Limitaciones

Anexo A. Criterios de severidad

1 RESUMEN EJECUTIVO

EN UNA FRASE

La aplicación protege bien el acceso, pero dos fallos de autorización permiten a un usuario consultar o modificar datos de otras cuentas. Recomendamos corregirlos antes del próximo lanzamiento.

CRÍTICA	ALTA	MEDIA	BAJA	INFORMATIVA
0	2	1	1	0

Qué significa para el negocio

Un usuario registrado como cliente podría descargar facturas con datos fiscales de otras empresas y darse permisos de administrador en su equipo. Es fácil de explotar y afectaría a la confianza de todos los clientes; por eso recomendamos corregirlo antes del próximo lanzamiento.

Qué está bien

- El inicio de sesión, la gestión de sesiones y el cifrado en tránsito están bien resueltos. No se han encontrado inyecciones ni secretos expuestos en el código del navegador.

Decisiones recomendadas

1. Corregir SX-01 y SX-02 antes del próximo lanzamiento.
2. Planificar SX-03 en el próximo sprint.
3. Solicitar el retest cuando las correcciones estén desplegadas (incluido durante 6 meses).

2 ALCANCE Y AUTORIZACIÓN

ACTIVO	TIPO	ENTORNO	ROLES PROBADOS
`app.ejemplo.com`	Aplicación web	Preproducción	Usuario, administrador
`api.ejemplo.com/v1`	API REST	Preproducción	Usuario, administrador

Fuera de alcance	Denegación de servicio, ingeniería social, infraestructura interna, servicios de terceros.
Autorización	Firmada por la dirección técnica de Ejemplo SaaS, titular de los sistemas, el 10/10/2026. Referencia: AUT-2026-00 (ejemplo).
Ventana de pruebas	Del 13 al 17 de octubre de 2026, de 9:00 a 19:00.
Contactos	Responsable técnico y teléfono de urgencias del cliente (ocultos en este ejemplo).
IP de origen	198.51.100.23 (rango de documentación, ejemplo).

3 METODOLOGÍA

Pruebas manuales apoyadas en herramientas, dentro del alcance autorizado. Cada hallazgo de este informe se ha verificado a mano; los resultados de herramientas sin verificar no se incluyen.

- **Entender:** revisión de la aplicación, sus roles, flujos críticos e integraciones.
- **Evaluar:** pruebas según OWASP WSTG, OWASP API Security Top 10 y OWASP ASVS nivel 2 en los controles aplicables.
- **Priorizar:** severidad según el Anexo A, ajustada al contexto de negocio.
- **Corregir:** recomendación específica para el stack y retest de lo corregido.

4 RESUMEN DE HALLAZGOS

Todos los hallazgos de este documento son ficticios.

ID	HALLAZGO	SEVERIDAD	PRIORIDAD	ESTADO
SX-01	Acceso a facturas de otras cuentas cambiando el identificador `GET /api/v1/invoices/{id}`	Alta	Inmediata	Abierto
SX-02	Un usuario sin rol de administración puede invitar administradores `POST /api/v1/team/invite`	Alta	Inmediata	Abierto
SX-03	Sin límite de intentos en el inicio de sesión `POST /api/v1/auth/login`	Media	Próximo sprint	Abierto
SX-04	Cabeceras de seguridad incompletas `app.ejemplo.com`	Baja	Planificada	Abierto

5 DETALLE DE LOS HALLAZGOS

SX-01 · Acceso a facturas de otras cuentas cambiando el identificador

■ Alta

Activo	`GET /api/v1/invoices/{id}` · api.ejemplo.com
Categoría	OWASP API1 · Autorización rota a nivel de objeto
Referencia CVSS	CVSS v3.1 6,5 · AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Descripción

La API devuelve cualquier factura a partir de su identificador sin comprobar que pertenece a la cuenta de la sesión.

Evidencia

```
GET /api/v1/invoices/10482 HTTP/1.1
Host: api.ejemplo.com
Authorization: Bearer eyJ…<recortado; sesión de la cuenta A>

HTTP/1.1 200 OK
{ "id": 10482, "account": "cuenta-B", "tax_id": "<enmascarado>", … }
```

Pasos para reproducir

1. Iniciar sesión con la cuenta A y obtener el token.
2. Solicitar `GET /api/v1/invoices/{id}` con el identificador de una factura de la cuenta B.
3. La API responde 200 con los datos de la factura de B.

Impacto

Cualquier usuario registrado puede descargar las facturas de otros clientes, con sus datos fiscales.

Recomendación

Comprobar en el servidor que la factura pertenece a la cuenta de la sesión antes de devolverla, preferiblemente en una capa común (middleware o consulta filtrada por cuenta) para cubrir el resto de recursos.

Referencias: OWASP API Security Top 10 (API1:2023); OWASP ASVS V4 (control de acceso).

6 PLAN DE CORRECCIÓN

PLAZO	HALLAZGOS	RESPONSABLE SUGERIDO
Inmediato (antes del próximo lanzamiento)	SX-01, SX-02	Backend
Próximo sprint	SX-03	Backend
Planificado	SX-04	DevOps

7 RETEST

El retest de los hallazgos críticos y altos está incluido durante los 6 meses siguientes a la entrega de este informe. Al completarlo se emite la versión 1.1 con el estado de cada hallazgo.

ID	FECHA DEL RETEST	ESTADO	COMENTARIO
SX-01	—	Pendiente	—
SX-02	—	—	—

8 LIMITACIONES

Este informe refleja las pruebas realizadas sobre el alcance indicado, en el periodo y con la información disponibles. No garantiza la ausencia de otras vulnerabilidades ni certifica el cumplimiento de ninguna norma. Los cambios posteriores en la aplicación pueden introducir riesgos nuevos.

ANEXO A. CRITERIOS DE SEVERIDAD

La severidad combina el impacto y la probabilidad de explotación, ajustados al contexto del negocio. CVSS se usa como referencia, no como único criterio.

SEVERIDAD	CRITERIO	PLAZO ORIENTATIVO
Crítica	Explotable sin autenticación o de forma trivial; compromete datos de muchos usuarios, permite ejecutar código o tomar el control.	Inmediato (días)
Alta	Acceso a datos o funciones de otros usuarios, o escalada de privilegios, con requisitos bajos.	Antes del próximo despliegue
Media	Requiere condiciones adicionales o tiene impacto limitado, pero facilita otros ataques.	Próximo sprint
Baja	Debilidad de configuración o de defensa en profundidad con impacto directo reducido.	Planificado
Informativa	Buenas prácticas u observaciones sin riesgo directo.	Opcional